

NAME: Mary Nyambura Gitau
GMAIL:marynyambura657@gmail.com
ADMISSION NUMBER: CS-SA12-26067

INTRODUCTION TO CYBERSECURITY ON TRY HACK ME

1.WEB APPLICATION SECURITY ON TRY HACK ME

1.1 Introduction

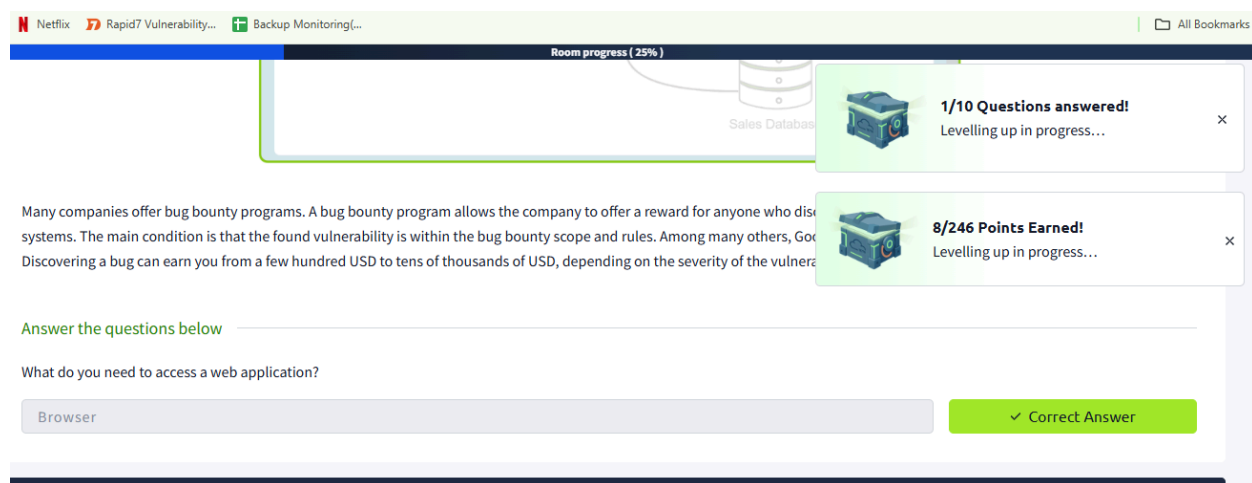
In this module , I understood the top 10 OWASP vulnerabilities. I majorly covered the broken access, SQL injection , identification and authentication failures plus IDOR (insecure Direct Object Reference).

A web application is a program that we use without installation as long as we have a browser like Mozilla Firefox.

Question

1.What do you need to access a web application?

Answer: Browser



1.2 Web Application Security Risk.

In this module I covered injections, identification and authentication failures, IDOR and broken access control.

Questions.

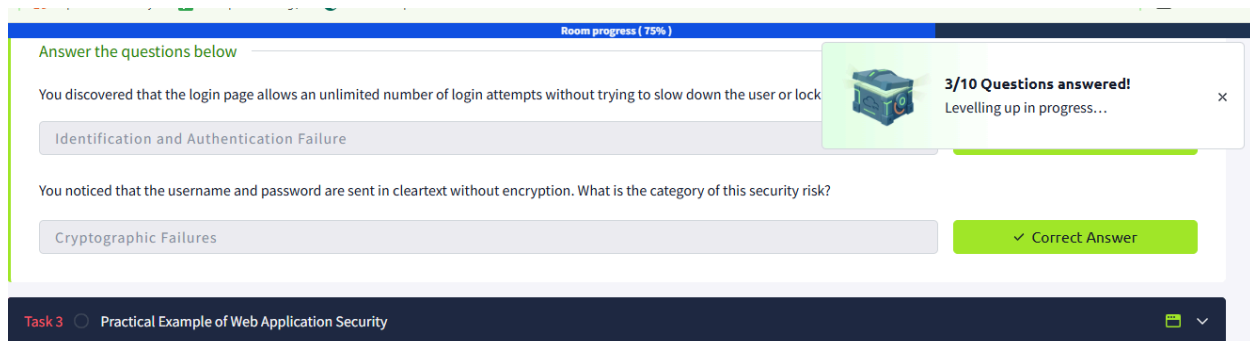
1. You discovered that the login page allows an unlimited number of login attempts without trying to slow down the user or lock the account. What is the category of this security risk?

Answer: **Identification and Authentication Failure**

2. You noticed that the username and password are sent in cleartext without encryption. What is the category of this security risk?

Answer: **Cryptographic Failures**

Screenshot evidence for both questions:



1.3 Practical Example of Web Application Security

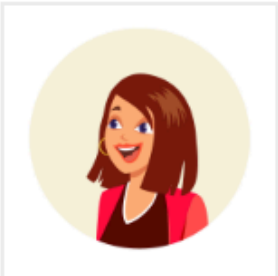
In this module, I did a practical example of how an IDOR occurs. I was given a site that had an IDOR vulnerability. https://inventory-management.thm/activity?user_id=11 this is the original id provided. I used a different id to get the hacker. ID=9 is the hacker.

https://inventory-management.thm/activity?user_id=9

Main Planned Shipments Inventory Your Activity

Inventory Management System

Your Activity



Employee Id:
9

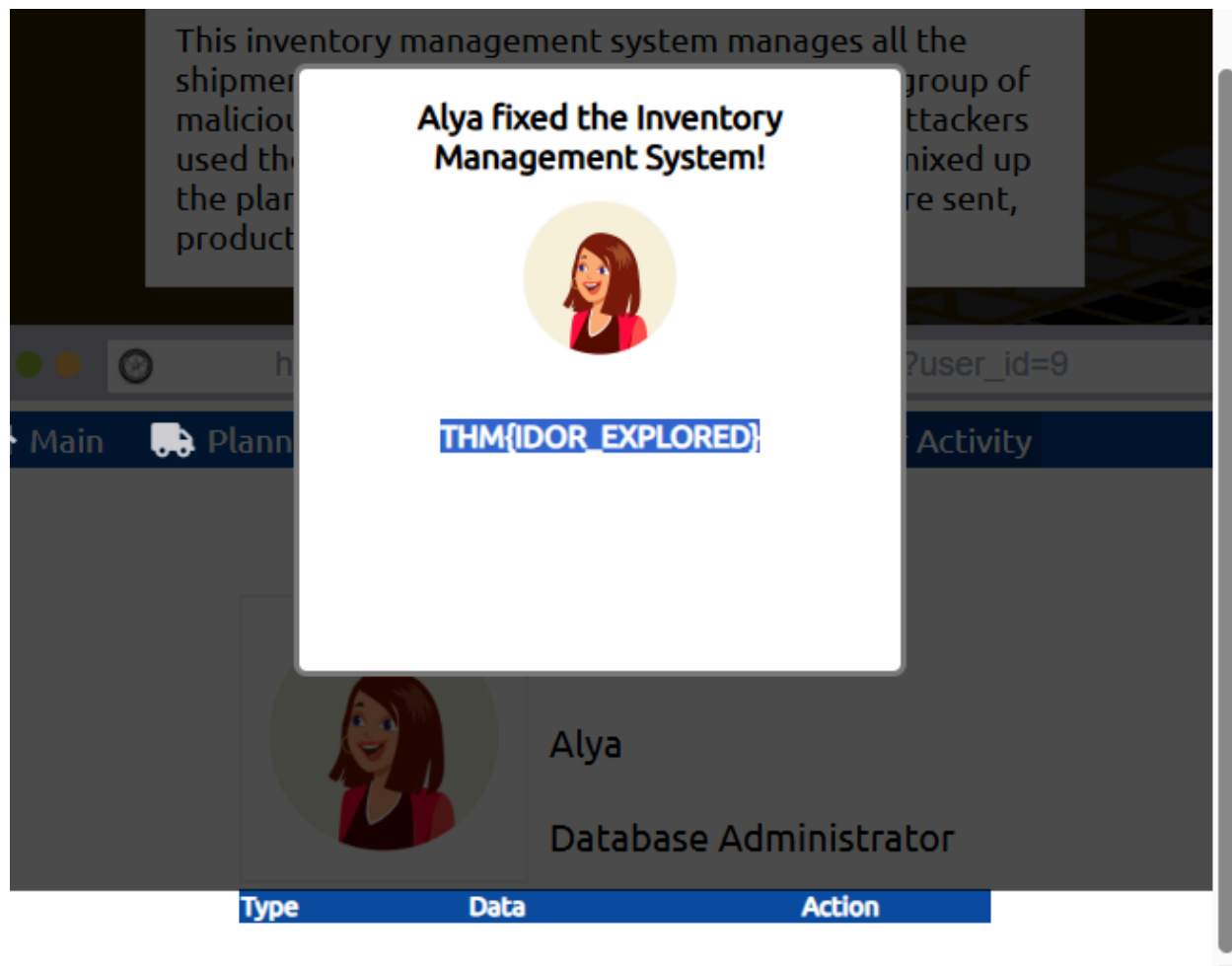
Name:
Alya

Position:
Database Administrator

Type	Data	Action
SKU Change	Inventory SKU0013 Changed	<button>Revert</button>
SKU Change	Inventory SKU0015 Changed	<button>Revert</button>
SKU Change	Inventory SKU0253 Changed	<button>Revert</button>
SKU Change	Inventory SKU0257 Changed	<button>Revert</button>
SKU Change	Inventory SKU0522 Changed	<button>Revert</button>
SKU Change	Inventory SKU0524 Changed	<button>Revert</button>

Show desktop

I reverted all the actions and got the flag **THM{IDOR_EXPLORED}**



Question:

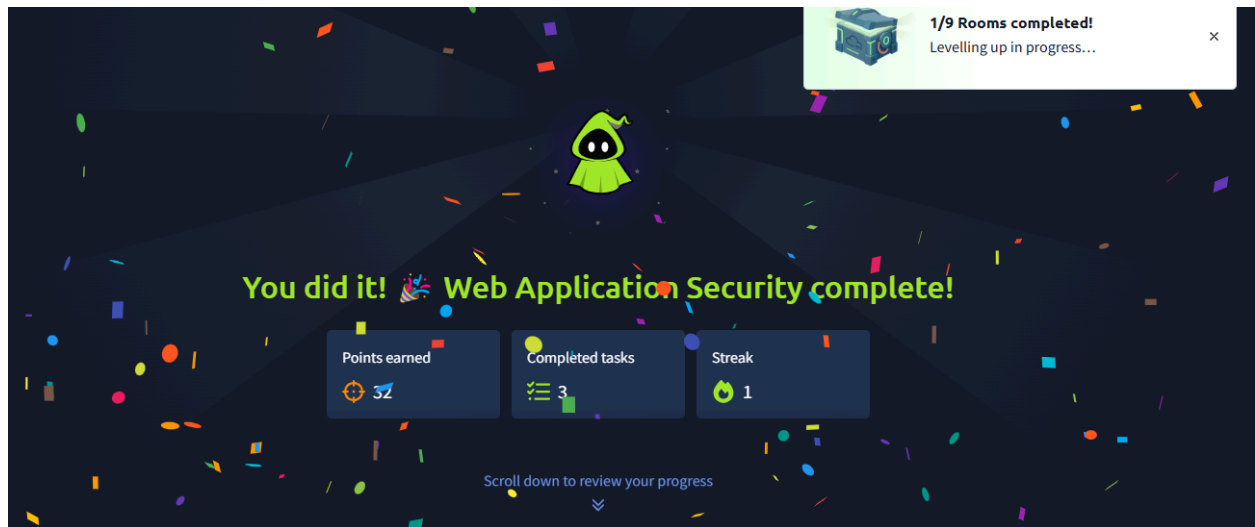
Check the other users to discover which user account was used to make the malicious changes and revert them. After reverting the changes, what is the flag that you have received?

Answer: **THM{IDOR_EXPLORED}**

1.3 Conclusion

This module has broadened my knowledge on web application security. The IDOR vulnerability has really stood out to me and understanding the concept will help me as a security analyst to curb future vulnerabilities.

Screenshot on completion of the module .



2.1 Offensive Security Intro

In this module I have understood the difference between defensive and offensive security.

Question

Which term describes simulating a hacker's actions to find weaknesses?

Answer: Offensive Security.

Room progress (25%)

Offensive Security is about thinking like an attacker to find weaknesses before real hackers do.

In this room, you'll hack your first website in a safe and legal environment to see how ethical hackers operate.

Answer the questions below

Which term describes simulating a hacker's actions to find weaknesses?

- Offensive Security
- Defensive Security

Offensive Security

**5/10 Questions answered!**
Levelling up in progress...

**40/246 Points Earned!**
Levelling up in progress...

✓ Correct Answer

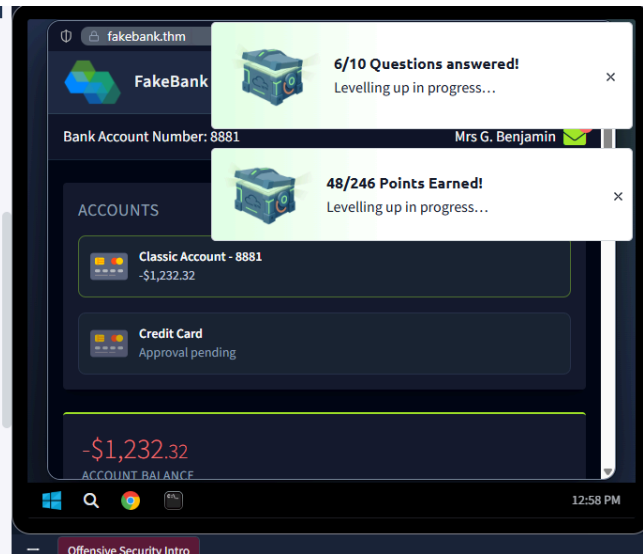
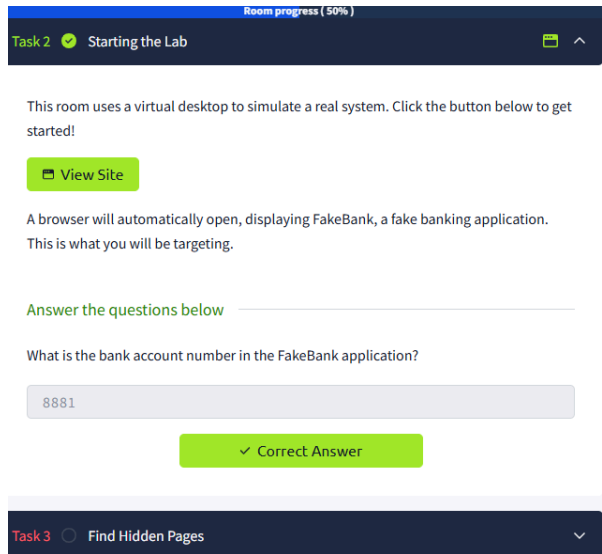


2.1.1 Lab

Question

What is the bank account number in the FakeBank application?

Answer: 8881

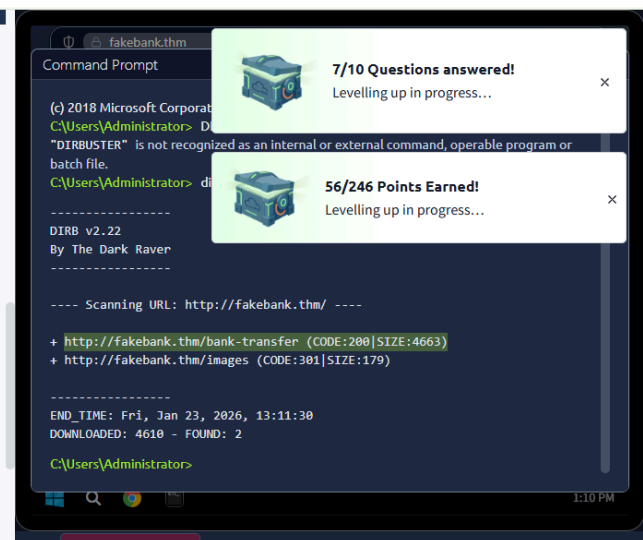
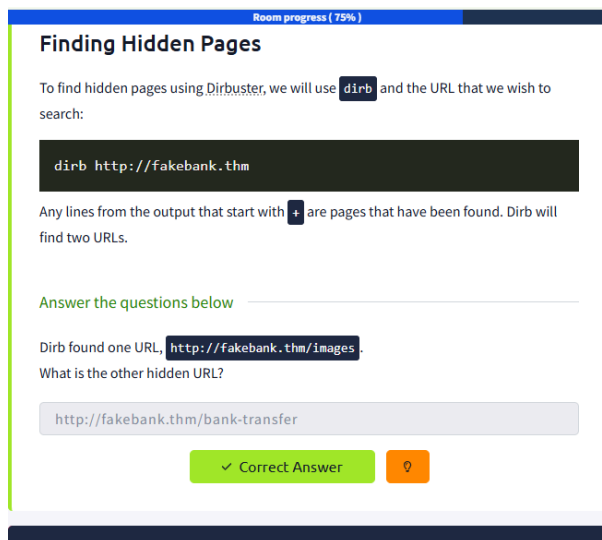


2.1.2. Dirb found one URL, <http://fakebank.thm/images>.

What is the other hidden URL?

Answer: <http://fakebank.thm/bank-transfer>

Explanation: I used the dirb command +url to find the other url.



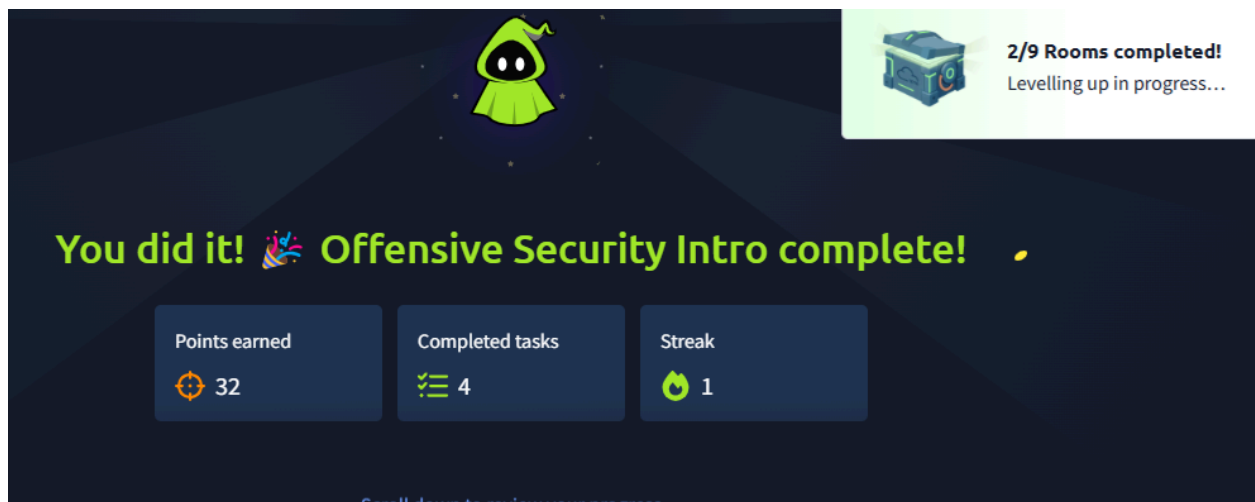
2.1.3 Attack the admin page

Question:

When your balance turns positive, a pop-up with green text appears.

Enter the green words as the answer (ALL CAPS)

Answer:**BANK-HACKED**



3.1 Introduction to defensive Security

This module has taught me on how to be a blue teamer.

Question.

What is defensive security also known as?

Answer: **Blue Teaming.**

The screenshot shows a quiz interface with a progress bar at the top indicating 25% completion. Below the progress bar, there are four blue cards with text: 'leaked.', 'British Airways was fined £20 million for this incident.', 'partly due to outdated systems.', 'Marriott International settled a \$52 million lawsuit.', 'Government officials fined the organisation £3.07 million.', and 'leaked data policies.'. To the right of these cards, there are two green pop-up boxes: '9/10 Questions answered! Levelling up in progress...' and '72/246 Points Earned! Levelling up in progress...'. Below the cards, there is a green text prompt 'Answer the questions below' and a question 'What is defensive security also known as?'. The answer 'Blue Teaming' is entered in a text box, and a green button labeled 'Correct Answer' is visible.

3.1.1 Responsibility of Defensive Security

This module taught me the different responsibilities of the blue team.

Question.

An attack has been detected on an organisation's network. What is the name of the person above who would be responsible for responding to the attack?

Answer: **Aaliyah**

The screenshot shows a quiz interface with a progress bar at the top indicating 25% completion. Below the progress bar, there are four blue cards with text: 'Bob monitors events on the organisation's network and systems to identify suspicious or expected behaviour.', 'He is at the frontline of protecting the organisation.', 'Aaliyah is responsible for investigating and responding to ongoing security incidents within the organisation.', 'She will monitor and prevent attackers in real time and share lessons learned during the attack to prevent future incidents.', 'Zoe develops and maintains essential tools and systems support the defensive security team.', 'These systems enable the team to monitor, investigate, and explore events within an organisation.', and 'analyse evidence from the network and systems to uncover vital information about the attackers and their methods.'. To the right of these cards, there is a green pop-up box: '10/10 Questions answered! Task complete!'. Below the cards, there is a green text prompt 'Answer the questions below' and a question 'An attack has been detected on an organisation's network. What is the name of the person above who would be responsible for responding to the attack?'. The answer 'Aaliyah' is entered in a text box, and a green button labeled 'Correct Answer' and an orange button with a question mark are visible.

3.1.2 Defensive Security in Practice

In this module I learnt about the different measures an organization can implement to keep the organisation secure. E,g: Employee training, security policies, firewalls , Intrusion Detection System.

Question

What is the abbreviation for the term "Security Operations Centre"?

Answer: SOC

SIEMs: The Defensive Security Radar

Much like a control centre in the real world, SIEMs (Security Information and Event Management) systems are the central place for all data and information collected from security devices, workstations, servers, and more within an organisation.

Much like radar sweeping the digital environment, these systems are an absolutely critical part of any organisation's defensive security, as they offer insight into what is happening within the organisation's IT.

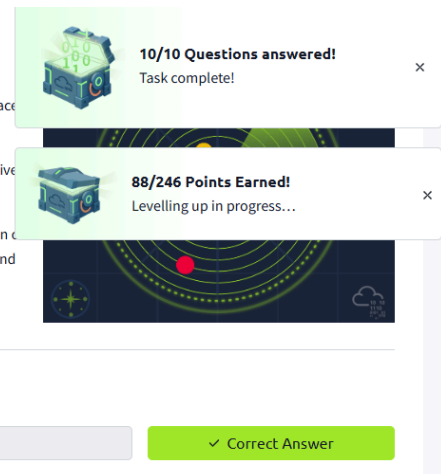
The systems inside an organisation produce a large amount of information. This information needs to be brought together in a central and easy-to-access place to understand what's happening quickly and clearly. This way, several people can review and analyse it quickly.

Answer the questions below

What is the abbreviation for the term "Security Operations Centre"?

SOC

✓ Correct Answer



3.1.3 Practical :Defend fake bank

In this module , I did a practical example of defending the bank from attackers and resolved the issue.

Question

What is the flag that you obtained by following along?

Answer: **THM{FAKEBANK-SECURED}**

Answer the questions below

What is the flag that you obtained by following along?

THM{FAKEBANK-SECURED}

✓ Correct Answer



The image shows a celebratory completion screen for the 'Defensive Security Intro' module on TryHackMe. The background is dark blue with colorful confetti. A central illustration shows a person in a blue suit sitting at a desk with a computer, with a green checkmark in a circle next to them. On the right, two white boxes with green borders announce achievements: '96/246 Points Earned! Levelling up in progress...' and '3/9 Rooms completed! Levelling up in progress...'. Below these, a large green banner reads 'Congratulations on completing Defensive Security Intro!!!'. At the bottom, a row of five dark blue boxes displays statistics: 'Points earned' (32), 'Completed tasks' (4), 'Room type' (Walkthrough), 'Difficulty' (Easy), and 'Streak' (1). At the very bottom, a green text line states '97,234 users are actively learning this week'.

96/246 Points Earned!
Levelling up in progress...

3/9 Rooms completed!
Levelling up in progress...

Congratulations on completing Defensive Security Intro!!!

Points earned	Completed tasks	Room type	Difficulty	Streak
32	4	Walkthrough	Easy	1

97,234 users are actively learning this week

Conclusion

The modules gave me a nice start to the cybersecurity field, eager to do more practical rooms in future exercise.

<https://tryhackme.com/p/marynyambura657>